

摘要：

国家互联网应急中心表示，OpenClaw拥有较高的系统权限，但其默认的安全配置极为脆弱，攻击者一旦发现突破口，便能轻易获取系统的完全控制权。建议部署OpenClaw时要强化网络控制、加强凭证管理、严格管理插件来源和持续关注补丁和安全更新。

人民日报3月10日消息，近期，开源AI智能体“龙虾”异常火爆，不仅受到国内产业界和广大用户的广泛关注，大家更是积极开展实践应用。与此同时，互联网上针对“龙虾”智能体安全的探讨也非常多，之前工业和信息化部网络安全威胁和漏洞信息共享平台也发布过相关的安全风险提示，大家也非常关注。“养龙虾”是否安全？个人用户“养龙虾”又该注意什么？记者采访了中国信息通信研究院副院长魏亮。

记者：广大用户非常关注工信部之前发布的“龙虾”安全风险提示，那么，在“龙虾”更新到最新版本后，是否就没有安全风险了？

魏亮：“龙虾”是开源AI智能体OpenClaw的别称，因为它的图标是红色的龙虾，所以得名。它通过整合调用通信软件和大语言模型，在用户本地电脑自主执行文件管理、邮件收发、数据处理等复杂任务。“龙虾”出现以后，受到我国产业界和广大用户的广泛关注，大家积极开展实践应用，推动了我国AI智能体生态的繁荣，但也要注意，到，“龙虾”很强的执行能力也给用户带来了严峻的安全挑战。

近期，工业和信息化部网络安全威胁和漏洞信息共享平台发布“关于防范OpenClaw开源AI智能体安全风险的预警提示”，针对存在的安全风险给出了一些防范建议。

目前，“龙虾”智能体更新迭代非常快，通过更新到官方最新版本，确实能修复已知的安全漏洞，但并不意味着完全消除安全风险。作为本地运行的AI代理，“龙虾”具有自主决策、调用系统资源等特点，加之信任边界模糊、技能包市场目前很多还缺乏严格审核，存在不少风险隐患。比如：在调用大语言模型时可能误解用户指令内容，导致执行删除等有害操作。使用被植入恶意代码的技能包，可能导致数据泄露或系统受控。因为将实例暴露于互联网、使用管理员权限、明文存储密钥等配置问题，即使升级到最新版本，如果不采取针对性的防范措施，依然存在被攻击风险。网络安全是动态的，黑客攻击手法也在不断迭代，不能把“打补丁”和“升版本”当成“一劳永逸”的安全保障。

我们呼吁，党政机关、企事业单位和个人用户要审慎使用“龙虾”等智能体。在发现“龙虾”等智能体的安全漏洞，或者针对“龙虾”等智能体的安全威胁和攻击事件时，可以第一时间向工业和信息化部网络安全威胁和漏洞信息共享平台报送，按照《网络产品安全漏洞管理规定》要求，平台将及时组织处置，切实维护网络安全，保障广大用户的权益。

记者：在使用“龙虾”智能体的过程中需要注意哪些方面？如何才能确保安全？

魏亮：这个问题非常关键。任何网络产品的安全使用，除了及时进行升级更新外，还必须坚持“最小权限、主动防御、持续审计”的原则。**结合前期发布的风险提示，建议从以下几方面来安全使用“龙虾”智能体。**

第一，使用官方最新版本。在部署时，要优先从官方渠道下载最新稳定版，并开启自动更新提醒。在升级前备份数据，升级后重启服务并验证补丁是否生效。切勿使用第三方镜像或旧版。

第二，严格控制互联网暴露面。一定不要将“龙虾”智能体实例暴露到公网，确需互联网访问的可以通过SSH或VPN，并且限制访问源地址，使用强密码或证书、硬件密钥等认证方式。同时，定期自查是否存在互联网暴露情况，一旦发现立即下线整改。

第三，坚持最小权限原则。在部署时，严禁使用管理员权限的账号，只授予完成任务必需的最小权限，对删除文件、发送数据、修改系统配置等重要操作进行二次确认或人工审批，建议在容器或虚拟机中隔离运行，以形成独立的权限区域。

第四，谨慎使用技能市场。ClawHub是专为“龙虾”智能体用户提供技能包的社区平台，其中的技能包存在恶意投毒风险，建议审慎下载，并在安装前审查技能包代码，拒绝任何要求“下载ZIP”、“执行shell脚本”或“输入密码”的技能包。

第五，防范社会工程学攻击和浏览器劫持。不要随意浏览来历不明的网站，避免点击陌生的网页链接。建议使用浏览器沙箱、网页过滤器等扩展阻止可疑脚本，启用OpenClaw速率限制和日志审计功能，遇到可疑行为立即断开网关并重置密码。

第六，建立长效防护机制。启用详细日志审计功能，定期检查并修补漏洞，党政机关、企事业单位和个人用户可以结合网络安全防护工具、主流杀毒软件进行实时防护。要定期关注OpenClaw官方安全公告、工业和信息化部网络安全威胁和漏洞信息共享平台等漏洞库的风险预警，及时处置可能存在的安全风险。

最后再次强调，广大用户在使用“龙虾”等AI智能体的过程中，一定要把安全底线把握在自己手中，详细了解并落实安全配置规范要求，养成安全使用习惯。我们也会持续做好安全监测，如发现相关安全风险将及时预警，为大家安全使用提供必要的技术支持。

同日，国家互联网应急中心发布关于OpenClaw安全应用的风险提示：

关于OpenClaw安全应用的风险提示

原创 CNCERT 国家互联网应急中心CNCERT 2026年3月10日 19:02 北京

近期，OpenClaw（“小龙虾”，曾用名Clawdbot、Moltbot）应用下载与使用情况火爆，国内主流云平台均提供了一键部署服务。此款智能体软件依据自然语言指令直接操控计算机完成相关操作。为实现“自主执行任务”的能力，**该应用被授予了较高的系统权限**，包括访问本地文件系统、读取环境变量、调用外部服务应用程序编程接口（API）以及安装扩展功能等。然而，**由于其默认的安全配置极为脆弱，攻击者一旦发现突破口，便能轻易获取系统的完全控制权。**

前期，由于OpenClaw智能体的不当安装和使用，已经出现了一些严重的安全风险：

1.“提示词注入”风险。网络攻击者通过在网页中构造隐藏的恶意指令，诱导OpenClaw读取该网页，就可能导致其被诱导将用户系统密钥泄露。

2. “误操作”风险。由于错误的理解用户操作指令和意图，OpenClaw可能会将电子邮件、核心生产数据等重要信息彻底删除。

3.功能插件（skills）投毒风险。多个适用于OpenClaw的功能插件已被确认为恶意插件或存在潜在的安全风险，安装后可执行窃取密钥、部署木马后门软件等恶意操作，使得设备沦为“肉鸡”。



4.安全漏洞风险。截止目前，OpenClaw已经公开曝出多个高中危漏洞，一旦这些漏洞被网络攻击者恶意利用，则可能导致系统被控、隐私信息和敏感数据泄露的严重后果。对于个人用户，可导致隐私数据（像照片、文档、聊天记录）、支付账户、API密钥等敏感信息遭窃取。对于金融、能源等关键行业，可导致核心业务数据、商业机密和代码仓库泄露，甚至会使整个业务系统陷入瘫痪，造成难以估量的损失。

建议相关单位和个人用户在部署和应用OpenClaw时，采取以下安全措施：

1.强化网络控制，不将OpenClaw默认管理端口直接暴露在公网上，通过身份认证、访问控制等安全控制措施对访问服务进行安全管理。对运行环境进行严格隔离，使用容器等技术限制OpenClaw权限过高问题；

2.加强凭证管理，避免在环境变量中明文存储密钥；建立完整的操作日志审计机制；

3.严格管理插件来源，禁用自动更新功能，仅从可信渠道安装经过签名验证的扩展程序。

4.持续关注补丁和安全更新，及时进行版本更新和安装安全补丁。

本文来源：[每日经济新闻](#)

风险提示及免责条款

市场有风险，投资需谨慎。本文不构成个人投资建议，也未考虑到个别用户特殊的投资目标、财务状况或需要。用户应考虑本文中的任何意见、观点或结论是否符合其特定状况。据此投资，责任自负。

限时0元领

*同一用户免费领取一次

扫码
免费领取



限免

139

收藏

分享到：

写评论

请发表您的评论

 表情

 图片

发表评论

3 条评论



手机用户
1小时前 中国山东省

欧美大模型、智能体、平台，能把全中国整个工业生产企业、科学技术研究机构、科学技术专利资料、全部工业化核心技术、中国全球产业链数据——进行学习、蒸馏、加空、打包彻底偷走。

0 回复



手机用户
2小时前 中国山东省

欧美AI赢不了中国，欧美早晚要对中国互联网发动特洛伊木马之战，只是时间问题。

0 回复



手机用户
2小时前 中国山东省



Bug是早晚可以修复，但你账户里的全部财产先归0，却没有人能替你要回来，国家应建立国家级沙箱安全测试基地，让专家把国外大模型全部测试一遍出具安全测试结果公告后，再开通国内下载，否则苹果手机客户账户、全国先吃螃蟹的那批人所有银行账户资产全部被洗劫成0，死的不是一批人，可能失去的是第一批吃螃蟹的人再无法回归行业生存，全国大面积账户资产被盗时无法索赔追回，连打官司的成本都没有机会都没有。

[展开全部](#) 

 0  回复

